

LAAM

Maturity, Roadmap & IP

Where the product stands today, capability by capability; how it has been engineered; what is still open; what is proposed next; and what the codebase depends on – with a full licence audit of its third-party runtime components.



VERSION
1.0

DATE
2026-09-24

CODE BASELINE
LAAM @ 7eb0724

Contents

1 Maturity summary

Status vocabulary · capability status matrix · deployment status

2 Development timeline

Milestones · release history · commit and velocity statistics

3 Engineering process & quality

Automated tests · type-check and lint · offline evaluation harness · review practice

4 Known limitations

5 Roadmap (proposed)

Pre-production hardening · product roadmap · scale-out

6 Intellectual property & dependencies

Codebase ownership · licence audit summary · service components · model weights · external-service vendor risk

A Appendix – dependency licence table

How to read this document

Every statement is true of the code at commit `7eb0724` (last commit 2026-09-17). Facts that cannot be derived from the code – legal entity, customers, pilot results, costs – are marked **TO BE COMPLETED** rather than estimated. Tests, type-check, lint, git statistics, code size and the licence audit were re-run on the baseline on 2026-09-24; other figures come from source-verified notes or carry their own date.

1 Maturity summary

LAAM is a self-hosted, multi-user conversational AI work assistant (chat and voice). It answers business questions against live data and acts through connected systems. In chat, every write to a connected system waits for the user's confirmation of a code-built preview; scheduled workflows may write only through tools marked workflow-safe and only to allow-listed recipients. It also runs durable, scheduled automation workflows. Its core is implemented and in daily internal use. It is **pre-production**: there are no production customers yet.

2.5.0

LAST TAGGED RELEASE
(+ UNRELEASED WORK
TO SEP 2026)

1,221

COMMITTS, JUN 1 → SEP
17 2026

3,573

AUTOMATED TEST
CASES (3,567 PASSING)

5

LLM PROVIDERS BEHIND
ONE ROUTER

1.1 Status vocabulary

LIVE implemented, wired, and exercised with real data and real external services in the self-hosted internal deployment (not production customer traffic). **BUILT** implemented and wired, with automated tests, but little or no use against real data yet. **PLANNED** roadmap item, or code that ships **off by default** behind an environment flag, or a reserved field; the Notes column says which.

1.2 Capability status matrix

Capability	Status	Notes
Assistant (chat)		
Chat with tool calling	LIVE	Streaming turns and a run-until-done tool loop (runaway backstop of 25 rounds). Attachments: images, PDF, DOCX, OCR. Rich tables, charts and maps.
Write confirmation gate	LIVE	In chat, every connector or MCP write is suspended into a sealed, 5-minute confirm token with a code-built preview. After the user confirms, the call runs with the sealed arguments and its nonce is checked against the audit log. Unknown tools are treated as writes. Scheduled workflows may write only through workflow-safe tools, to allow-listed recipients.
Grounding and anti-hallucination guards	LIVE	Code-built result tables, model-facing digests, "empty is not absent" annotation, write-claim guard, question pin. Each guard is tied to a measured failure.
Deterministic list→detail drilldown · data-fetch guard	PLANNED	Implemented and measured, but off by default (env-configured tool pairs).
Workspaces, custom agents (personas)	BUILT	Per-user conversation groups with one shared persona, plus reusable agent presets.
Models		
Cloud providers (two OpenAI-compatible)	LIVE	Default chat and background model when a key is configured. Full tool loop. Text only (no vision).
Local models (Ollama)	LIVE	Always available in the picker, \$0 marginal cost, vision supported. The router's final tier.
Third cloud provider (internal only)	BUILT	Used for background tasks through the internal router; not in the chat picker.

Capability	Status	Notes
Anthropic Claude	BUILT	Chat only: no tools, no vision. Fails loudly if asked to run an agent step.
Integrations		
MCP client (any remote MCP server)	LIVE	Per-user servers over Streamable HTTP with SSE fallback. Server URLs are checked at connect time against private and metadata address ranges after DNS resolution. A 200-tool cap and a per-tool allowlist. Measured with a 48-tool knowledge-graph / database MCP server.
12 built-in connectors (11 integrations + 1 offline demo) · 46 tools	BUILT	Source hosting, issue trackers, cloud documents, calendar, email, team chat, messaging, API catalogs. The OAuth connectors stay dormant until the operator registers OAuth apps.
LAAM as an MCP server	BUILT	Hand-written JSON-RPC over Streamable HTTP (the MCP client uses the official SDK). 9 read-only tools for external agents, behind personal access tokens. Every call is recorded as a monitored session.
Web search / read	LIVE	Self-hosted metasearch. The URL reader applies a hostname blacklist. Fails soft if the search service is down.
Automation		
Workflow engine (durable runs)	LIVE	5 frozen node kinds. Every step journaled. Crash-resume from the journal. Connector writes are claimed atomically per node: a resumed run never re-sends a completed write, and an unfinished one fails loudly instead of being retried. Dry-run mode.
Parallel DAG execution	BUILT	Opt-in per graph. A golden test proves linear graphs behave identically to the default walker.
Cron scheduler	BUILT	Atomic slot claim. Needs an external per-minute trigger; timezone is stored but server time is used.
AI workflow authoring	BUILT	One-shot and multi-turn. Grounded in observed tool calls, compiled by code from a plan, verified by a dry run before it is offered. Dry runs execute read tools for real; a read declared by an external MCP server may still have side effects on that server.
Voice		
Voice command centre	LIVE	Hands-free loop with barge-in (self-hosted VAD). Streaming self-hosted neural TTS in Vietnamese and English.
Speech-to-text	BUILT / PLANNED	v1 uses the browser Web Speech API. A self-hosted Whisper provider is a planned drop-in behind an existing interface.
Platform		
Access control (RBAC)	LIVE	4 roles (owner/admin/member/viewer), enforced on state-changing business routes since v2.4.0 (some personal and helper routes need only a session). Off-boarding runs in one transaction. Single organisation.
Access tokens (API / MCP / collector)	BUILT	Hashed at rest, revocable, expiring. Scopes are stored but not enforced (planned).
Credential encryption	LIVE	AES-256-GCM with per-user HKDF-derived keys, all derived from one server master secret.
Global search	BUILT	Trigram search over sessions, conversations (including message content) and workflows. Language-agnostic (vi/en/zh).
Monitoring (AI coding-agent sessions, chat and workflow runs)	LIVE	Parses agent transcripts from local and remote collectors. Records cost, tokens and model for chat and workflow runs.

Capability	Status	Notes
Notifications	BUILT / PLANNED	In-app bell (workflow outcomes, pending confirmations) is built. Email and chat delivery are planned.
Evaluation harness	LIVE	Runs against real models with stubbed tool responses. Results are charted in-app (see §3.4).
Internationalisation	BUILT	UI in Vietnamese (primary), English and Simplified Chinese. Voice in Vietnamese and English.
SSO · BYOK model keys · multi-instance scale-out	PLANNED	Not implemented; see §5.

■ 1.3 Deployment status

LAAM is **pre-production**. It runs as a self-hosted Docker Compose stack: the application container, a self-hosted TTS service, a self-hosted metasearch service and a database admin UI, against an external PostgreSQL 16 instance. Local models are served by a native Ollama on a GPU host. The stack is used today for development, internal use and demonstrations. No uptime, SLA or load figures have been measured, and none are claimed.

Item	Status
Production customers	None stated
Pilot deployments and results	TO BE COMPLETED
Target first production deployment	TO BE COMPLETED
Hosting model offered to customers (self-hosted / managed)	TO BE COMPLETED

2 Development timeline

A v1 prototype (a single-user monitoring dashboard) was replaced on 2026-06-03 by a full v2 rewrite. The rewrite brought Next.js 16, React 19, PostgreSQL and multi-user auth. Since then the product has grown from agent monitoring into a general AI assistant, in roughly 15 weeks.

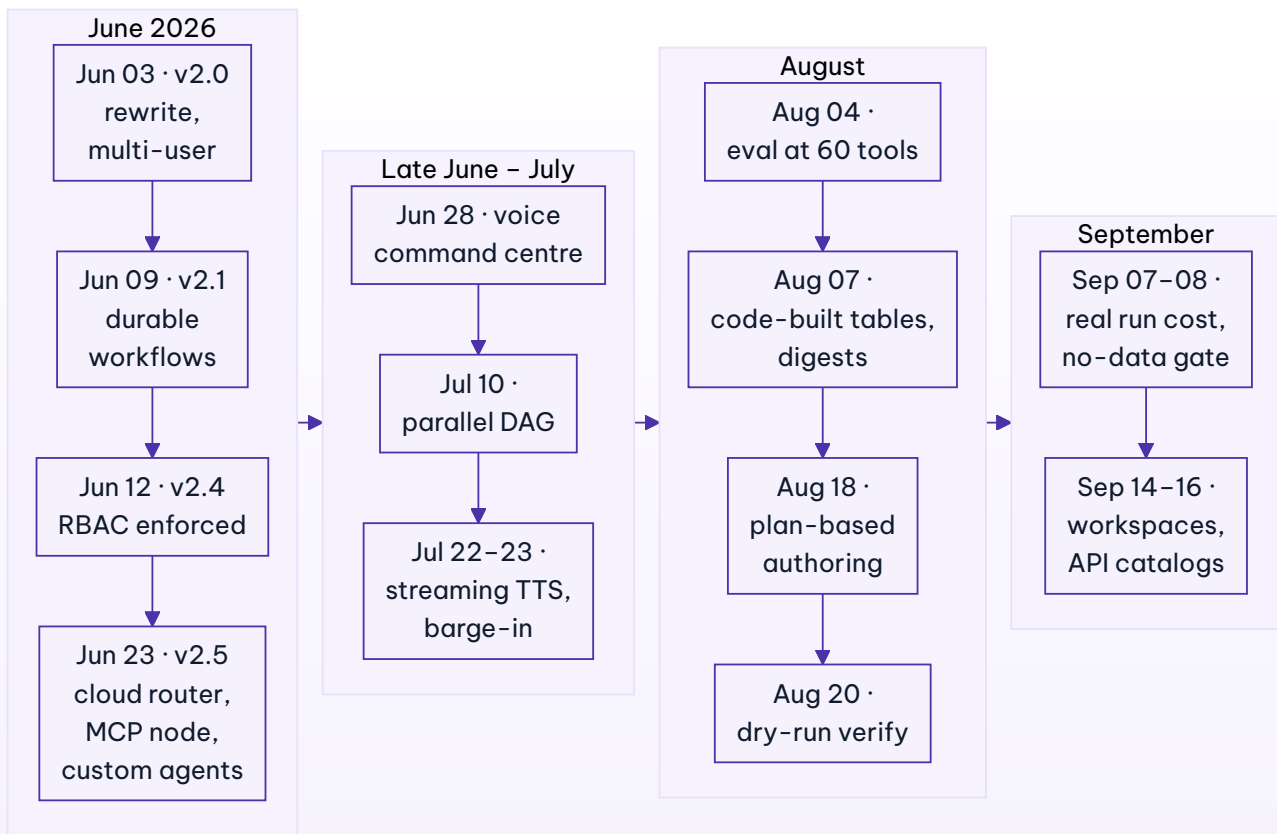


Figure 1. Major milestones from the release notes and the git history. Dates are commit dates.

• 2.1 Tagged releases

Tag	Date	Theme
v0.9.0	2026-06-03	v1 prototype, archived
v2.0.0	2026-06-03	Full rewrite: Next.js 16 + React 19 + PostgreSQL + Auth.js; multi-user and multi-machine; 7 connectors with encrypted credentials
v2.1.0	2026-06-09	Durable AI workflows, scheduler, recipient-gated email send, web search/read/calc tools, eval v2
v2.2.0	2026-06-11	Server-side PDF/DOCX, chat vision, search, run cancel, security headers, login hardening
v2.3.0	2026-06-12	Claude as an optional chat provider; workflow patterns
v2.4.0 / 2.4.1	2026-06-12	RBAC enforced, notifications, off-boarding, admin-provisioned access keys
v2.5.0	2026-06-23	Cloud-first internal router, message search, no-code-execution guard, multi-provider connector OAuth, per-user key derivation, SSRF DNS pinning, MCP workflow node, custom agents
Unreleased	→ 2026-09-17	Parallel workflows, voice, AI authoring pipeline, two more providers, workspaces, catalog connectors. Not yet tagged.

2.2 Commit and velocity statistics

1,134

COMMITTS AFTER THE
v2.0.0 TAG (1,221 IN
TOTAL)

52

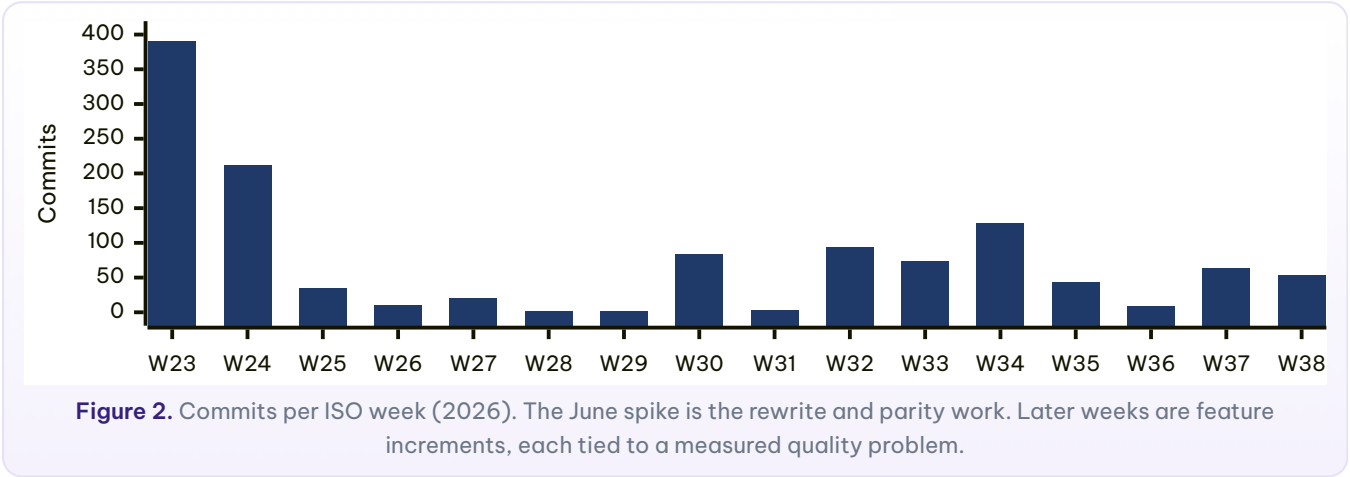
ACTIVE COMMIT DAYS

24

MERGED PULL
REQUESTS

8

TAGGED RELEASES



Metric	Value
Contributors	7 distinct commit identities (by email, including assistant and generic local identities), one of them a generic local identity not tied to a named person (90 commits). After removing aliases the human contributors are an estimated 2–3 people. TO BE COMPLETED – confirm headcount and roles.
Size at baseline	About 62.7k lines of application code (about 490 files) and 48.4k lines of test code under <code>src/</code> . Test-to-code ratio about 0.77.
Design artefacts in repo	39 written design specifications and 69 implementation plans, plus a detailed bilingual changelog

3 Engineering process & quality

The codebase is test-heavy and measurement-driven. Most behavioural guards in the agent loop cite the dated measurement that motivated them. Automated gates exist and pass on application code. What is missing is **enforcement**: there is no CI pipeline, so the gates are run by developers, not by the repository.

3.1 Automated tests (re-run on the baseline, 2026-09-24)

363

TEST FILES

3,573

TEST CASES COLLECTED

3,567

PASSING (99.8%)

~30–40 s

FULL-SUITE WALL TIME
(MACHINE-DEPENDENT)

Method. `vitest list` collected the cases and `vitest run` executed the full suite at commit `7eb0724` , using Vitest 4 with Testing Library and jsdom. The suite uses no live external services.

Failing file (6 cases)	Cause (as observed)	Assessment
Voice command-centre component (3)	jsdom has no WebGL context, and the component now renders a 3D scene	Test-environment gap
Eval runner (2)	Expected message-array shape no longer matches after a runner change	Pending triage
Scheduler tick (1)	A queued run is finalised twice instead of once	Pending triage – real behaviour change until proven otherwise

The history shows the suite growing with the product: 375 tests at v2.0.0, 1,337 at v2.1.0, 2,080 at v2.5.0 and 3,573 at this baseline. Notable guard tests: a **no-code-execution invariant** (a test in the suite fails if process spawning, `eval`, `new Function` or `vm` appears in the agent or workflow layers; there is no CI yet; it also pins the internal tool list and the workflow node kinds), a durable-resume integration test, scheduler-auth tests, i18n dictionary drift tests and a UI contrast test.

■ 3.2 Type-check and lint

Gate	Result at baseline	Detail
TypeScript (strict)	1 error	Application code is clean. The single error is a mock type in one test file.
ESLint 9 (Next.js config)	90 errors · 101 warnings	82 of the errors come from the newer React Hooks rules: set-state-in-effect 39, refs 35, purity 4, memoization 3, immutability 1. There are also 7 <code>prefer-const</code> and 1 import style. Most warnings are unused variables and expressions. A further 69 warnings come from vendored minified bundles that the config does not yet exclude. Lint is not currently a release gate.

■ 3.3 Change management and review

- **Branching.** Work happens on task branches merged through pull requests (24 merged so far). There is a separate deploy branch. Commits mostly follow conventional prefixes (`feat` , `fix` , `test` ...).
- **Design before code.** Larger features carry a written specification and plan in the repository (39 specs, 69 plans). Plans state their success criteria, and each merge records how verification was done.
- **Release notes.** A detailed changelog records, per change, the motivating measurement, the test delta and what was deliberately deferred.
- **Database migrations.** Only committed migrations are applied (19 so far: 17 generated, 2 hand-authored). Schema push is never used against real data.
- **Not present:** CI configuration, pre-commit hooks, branch-protection rules held in the repo, dependency-update automation, or container image scanning. Review is recorded in commit messages and pull requests, not enforced by tooling. These items are on the hardening roadmap (§5.1).

■ 3.4 Offline evaluation harness

A separate harness runs the **real** system prompt and the **real** tool loop against real models. Tool responses are **stubbed**: no live connectors are called, and flag-off features stay off. Each scenario runs *k* times, and eight graders score tool selection, arguments, grounding, restraint, termination, write

intent, rich-block rendering and source citation. Results are stored with the git SHA and charted on the in-app Reliability page.

Dimension	Tool selection	Arguments	Grounding	Restraint	Termination	Write intent	Rich block
Grader pass rate	86%	97%	67%	100%	90%	100%	100%

Run of 2026-09-03 (internal QA record). Model: gpt-oss-120b via a cloud provider. k = 5 × 17 synthetic scenarios = 85 runs, all with stubbed tool responses.

Caveats – these are grader pass rates, not accuracy

The scenarios are synthetic and the tool responses are stubbed, so these numbers are **not** end-to-end accuracy on customer data. The grounding grader checks that expected tokens appear in the answer. Its lowest scores come from scenarios where the model chose a different, plausible monitoring tool, and from one open-ended web-research scenario that ran 10–16 tool rounds.

A second suite measures **tool selection against tool count**. It uses 4, 16, 32 and 60 tools, where 60 is a measured real per-user tool surface of 12 internal tools plus 48 from one MCP server. It reports Wilson confidence intervals and separates "no call" from "wrong call". An early low-sample run (k = 3) suggested stable selection as tools grew; a later 60-tool run averaged 67%, so scaling is still being measured. At 60 tools the tool schema costs about 6k tokens per round, and a k = 16 re-run of the three highest-risk multi-step probes passed 16/16. These are stubbed-dispatch measurements for one model.

4 Known limitations

These are the documented gaps at the baseline. None prevents internal use and demonstrations. Items marked as hardening are pre-production work, and §5.1 lists them.

■ 4.1 Platform and operations

Area	Limitation
Single-process design	The live event bus, the login/registration rate limiters and workflow resume all assume one application process. Horizontal scale-out needs a shared bus and limiter store.
Scheduler trigger	Schedules fire only when an external per-minute trigger calls the tick endpoint (today a host-level scheduled task). There is no in-process timer. After a gap, one run fires and the other missed slots are counted, not back-filled. Timezone is stored, but schedules evaluate in server time.
Hardening items before production	API-wide rate limiting (only login and registration are limited today). A Content-Security-Policy header (the other security headers are set). Enforcement of access-token scopes, and per-user data isolation on the MCP-server read tools (the audit tool is already scoped). One DNS-pinned guard for all outbound fetches. An atomic nonce claim and idempotent retry for confirmed MCP writes. Secure defaults, a managed scheduler trigger, key management, observability, backups and CI/CD. §5 lists the full set.
Authentication	Email and password only; there is no SSO. The auth library is Auth.js v5 beta (next-auth 5.0.0-beta.31), a pre-release of its v5 major version.
Key management	All per-user credential keys derive from one server master secret. There is no KMS/HSM integration or key rotation tooling yet.

Area	Limitation
Observability	Logging goes to the console only. There is no structured logger, APM or tracing. Cost figures use a manually maintained price table, flagged in code as possibly stale.
Container images	Two auxiliary images (metasearch, database admin UI) track <code>latest</code> rather than pinned versions. The admin UI is a development convenience; before production it should be bound to a private interface or dropped from the stack.
Remote monitoring detail	Sessions pushed by remote collectors carry metadata only, so the per-session tool waterfall works only for transcripts on the server host.

■ 4.2 AI and product

Area	Limitation
Provider feature parity	Vision is available only on local models. The Claude provider is chat-only (no tools). Model keys are organisation-level; there is no per-user bring-your-own-key.
Provider failover	There is no automatic cross-provider failover during a turn. A provider error fails loudly, with a coded, translated notice. The router's ordered tiers (cloud providers, then local) choose the default model per deployment configuration.
Evaluation coverage	The offline suites use stubbed tools and one primary model. No end-to-end accuracy benchmark on customer data exists yet (see §3.4).
Speech-to-text	The browser's Web Speech API routes audio through the browser vendor. It works in Chromium-family browsers only.
Workflow authoring	The multi-turn authoring conversation lives in the browser and is lost on reload. It is capped at 20 turns. One legacy compile endpoint has no UI caller.
Connector neutrality	The integration layer is generic, but a few model-facing prompt strings still reference one knowledge-graph server's tools. Cleanup is tracked.
Notifications	In-app only. Email and chat delivery, and role-wide broadcast (the field is reserved), are not built.
Quality gates	6 failing test cases, 1 test-file type error and outstanding lint errors (§3). No CI enforces them.

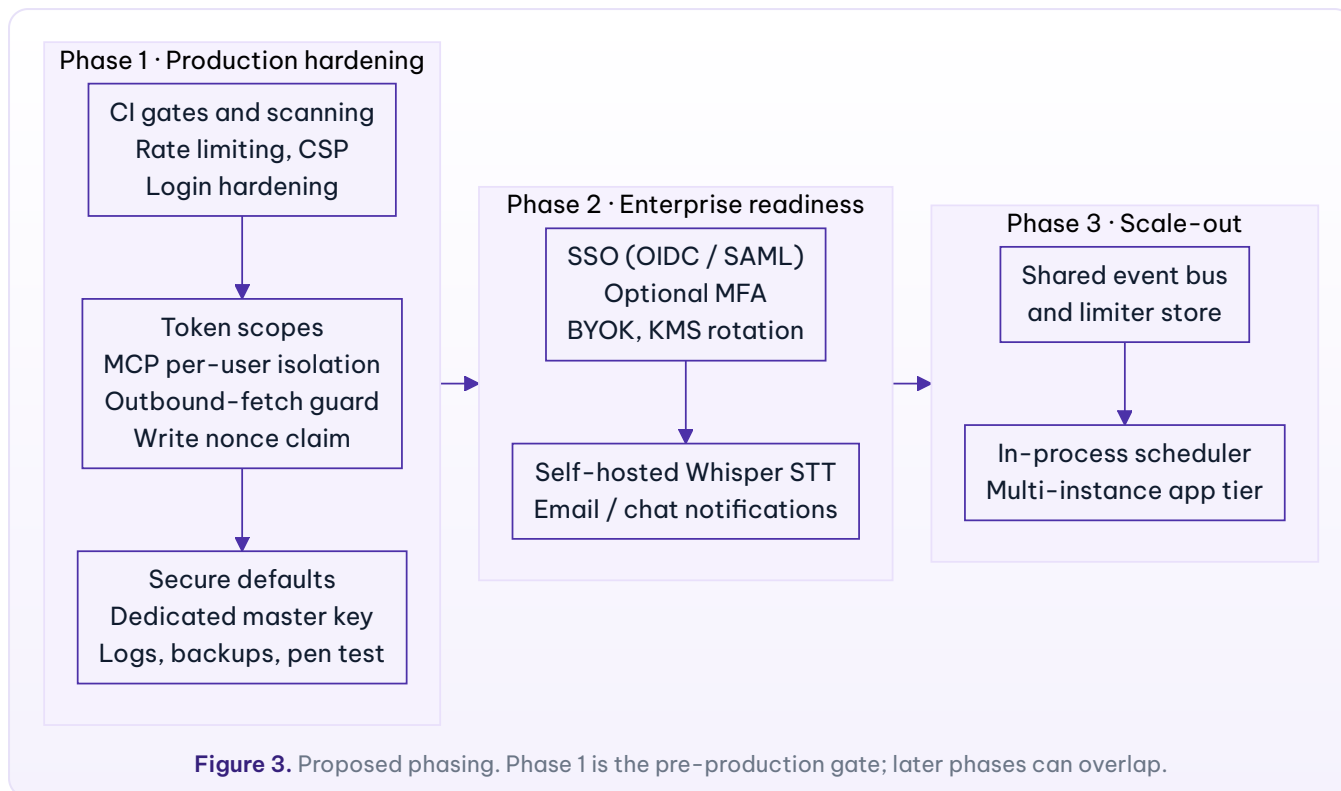
5 Roadmap PROPOSED

This roadmap comes from the flag-off and partial features in the code, and from items the changelog marks as deferred. It is a **proposal**. Sequencing and dates depend on funding and early customer feedback. TO BE COMPLETED – confirm the committed timeline and owners.

■ 5.1 Phase 1 – production hardening

Phases 1–3 together cover every hardening item listed in Document 03 §8. Phase 1 is the minimum gate for a first production deployment; the identity and key-management items in Phase 2 and shared state for replicas in Phase 3 complete that list.

Item	Starting point in the code
CI pipeline with test (including the code-execution guard test), type-check and lint gates, dependency and image scanning, and migrations; triage the 6 failing cases; exclude vendored bundles from lint	All three gates already run locally (§3)
API-wide rate limiting (per user and per token, plus edge limits at the proxy); rate-limit keys from a trusted proxy's client address; uniform login response timing	An in-memory limiter exists for login and registration; extend it to all routes, backed by a shared store
Content-Security-Policy	The baseline security headers are already set; CSP was deliberately deferred
Enforce access-token scopes; per-user isolation for MCP-server tools; move the auth library to a stable release	Scopes are already stored per token; the isolation path is reserved in the schema; the beta auth library is pinned exactly
One DNS-pinned guard for all outbound fetches (URL reader, URL fetch, MCP), covering the carrier-grade NAT range and re-checked on every redirect	MCP server URLs are checked after DNS resolution at connect time; the URL reader applies a hostname blocklist
Atomic nonce claim and idempotent retry for confirmed MCP writes	Confirmed calls already carry a nonce that is checked against the audit log
Secure defaults: invite-only sign-up; app, admin UI and metrics agent on private interfaces; database connection string in the environment file; pinned auxiliary image versions	Sign-up mode (open / invite / closed) is already configurable; Compose file
Managed scheduler trigger with a mandatory tick secret	The tick endpoint and its auth tests exist; today a host-level scheduled task calls it
Dedicated master key from a secret manager, mandatory at boot and separate from the session-signing secret; re-encrypt remaining legacy blobs	Per-user key derivation from one master secret; a versioned blob format
Structured logging, tracing, alerting and a readiness endpoint	Console logging today
Re-point backups; restore drills; RPO/RTO targets	A backup script and restore procedure exist but still target the previous database container
Third-party notices for the vendored browser assets (§6.3)	ONNX Runtime Web, the Silero VAD model and the VAD worklet bundle are committed without notice files
Third-party penetration test and a review of the AI write gate	The write gate is covered by unit tests



■ 5.2 Phase 2 – enterprise and product

Item	Starting point in the code
Single sign-on (OIDC / SAML), optional MFA	The auth framework supports external providers; only credentials login is configured
Per-user bring-your-own model keys; KMS/HSM-backed master key with rotation	Per-user key derivation already exists; the changelog lists BYOK as a follow-up
Self-hosted Whisper speech-to-text	A swappable speech-to-text provider interface is already in place
Vision on cloud providers; tool use on the Claude provider	Provider adapters already exist
Email and chat notification delivery; role broadcast	Single notification chokepoint plus a reserved audience field
Enable drilldown and the data-fetch guard by default for suitable connectors	Implemented and measured; off by default
Workflow deferrals: parallel execution by default (then retire the linear walker), per-node optional/degrade flags, wall-clock run timeout, persisted authoring threads	Listed as deferred in the changelog
End-to-end evaluation on first-customer data, and a second primary model in the eval matrix	The harness already supports multiple providers

■ 5.3 Phase 3 – scale-out

Replace the in-process event bus and limiters with a shared store, and move the scheduler trigger into the product. This removes the external trigger, adds timezone/DST handling and catch-up, and makes

crash-resume safe with multiple workers (row claims already use `FOR UPDATE SKIP LOCKED`). Also forward remote-collector events so session detail works for every machine. Then run several stateless app instances behind a load balancer.

6 Intellectual property & dependencies

6.1 Codebase ownership

Item	Position
Nature of the code	Proprietary and closed-source. The package is marked private, and the repository has no open-source licence file. All application code, the agent loop, guards, workflow engine, authoring pipeline, connectors and collectors is first-party. Third-party code enters as package dependencies (§6.2), unmodified service containers (§6.3) and vendored browser assets under <code>public/vad</code> (ONNX Runtime Web, the Silero VAD model and the VAD worklet bundle, §6.3).
Owning legal entity	TO BE COMPLETED
Contributor IP assignment (employment / contractor agreements)	TO BE COMPLETED
AI-assisted code	AI coding assistants are used as part of the development workflow, under the direction of the team's contributors. TO BE COMPLETED – legal confirmation of ownership position and of the assistant providers' output terms.
Generic local commit identity	90 commits were made under a generic local identity that is not tied to a named person. TO BE COMPLETED – attribute these commits to their contributors for the IP-assignment record.
Patents / trademarks	TO BE COMPLETED – none filed are known from the repository.

Where the proprietary value sits. The integrations are standard protocols. The differentiated work is the layer of code-enforced reliability around the model: the write-confirmation gate with sealed confirm tokens whose nonce is checked against the audit log; code-built tables and digests, so the model never retypes data; structural grounding guards, each tied to a measured failure; MCP tool-name de-collision; trace-grounded workflow authoring (plan DSL → guard → compile → dry-run verify); the durable, idempotent workflow journal; and the measurement harness that tunes all of the above.

6.2 Third-party runtime dependencies – licence audit

Method. An offline script read the `license` field of each installed package manifest. It covered the 33 direct production dependencies in `package.json` and the full production closure recorded in the lockfile (540 entries; development-only packages excluded). Missing fields were resolved from the package's LICENSE file. Nothing was installed or fetched.

Direct production dependencies (33)

Licence	Count
MIT	22
ISC	4
Apache-2.0	3

Full production closure (540 lockfile entries)

Licence	Count
MIT (incl. MIT-compatible combos)	414
ISC	51
Apache-2.0	25

Licence	Count
BSD-3-Clause / BSD-2-Clause	1 / 1
Unlicense (public-domain dedication)	1
Hippocratic-2.1	1

Licence	Count
BSD-3 / BSD-2 / 0BSD	22 / 3 / 1
Unlicense · CC0-1.0	3 · 1
MPL-2.0 OR Apache-2.0 (dual)	1
CC-BY-4.0 (data)	1
Hippocratic-2.1	2
LGPL-3.0 family (optional binaries)	14
Resolved from LICENSE file → MIT	2

Items flagged for review

Component	Licence	Observation and suggested position
<code>react-leaflet</code> , <code>@react-leaflet/core</code> (map rendering)	Hippocratic-2.1	Highest-priority item. This is an "ethical source" licence: not OSI-approved, and it restricts field of use (human-rights conditions). It is not copyleft, but commercial customers' procurement may reject it. Options are legal review, or replacing it with a thin first-party wrapper over the BSD-2 <code>leaflet</code> library, which LAAM already uses directly.
<code>@img/sharp-*</code> platform binaries (14 lockfile entries, one installs per platform)	LGPL-3.0-or-later (libvips)	An optional native dependency of the framework's image pipeline, dynamically linked and unmodified. Under the usual reading, shipping it as a separate, unmodified shared library with its licence notice satisfies LGPL, and first-party code is not affected. Confirm with counsel.
<code>dompurify</code>	MPL-2.0 OR Apache-2.0	Dual-licensed; elect Apache-2.0.
<code>caniuse-lite</code>	CC-BY-4.0	Browser-support data used at build time; attribution only.
<code>rgbcolor</code> (optional, via the PDF export library)	MIT OR custom	Elect MIT.
<code>khroma</code> , <code>webgl-constants</code>	(no manifest field)	Resolved from their LICENSE files: MIT.

Copyleft result

No GPL, AGPL or SSPL licence appears in the npm runtime dependency tree. The only LGPL component is the optional, dynamically linked image library above. The one non-OSI licence (Hippocratic-2.1) is on the map-rendering component and should be reviewed before commercial distribution.

6.3 Service components and system binaries

Component	Licence	How it is used · implications
SearXNG (web metasearch)	AGPL-3.0	Separate, unmodified upstream container, called over its JSON API on the internal network; no code is linked or embedded. Under the usual reading, AGPL's source-offer duty attaches to modified versions offered over a network, so first-party code is not affected. Keep it unmodified, and confirm with counsel.
VieNeu-TTS engine (Python package)	Apache-2.0 per an in-repo note	Self-hosted container, CPU-only, torch-free ONNX runtime. The service wrapper is first-party. TO BE COMPLETED – verify the package licence from its distribution.

Component	Licence	How it is used · implications
VieNeu-TTS model checkpoint	Not stated in repo	Baked into the TTS image at build time. TO BE COMPLETED – confirm the model-card licence permits commercial use.
English voice preset	Provenance to confirm	A speaker embedding enrolled from a short reference clip. In-repo notes disagree on which third-party speech synthesiser produced the clip. TO BE COMPLETED – confirm the rights, or replace it with a recorded, licensed clip. The Vietnamese voice is a built-in preset of the engine.
Silero VAD model · ONNX Runtime Web · VAD worklet bundle (vendored under <code>public/vad</code>)	MIT · MIT · ISC	Committed copies served to the browser for barge-in detection. No licence notice files are committed alongside them yet; adding a third-party notices file is a Phase 1 item (§5.1).
Ollama (local model server)	MIT	Native install on the GPU host; unmodified.
poppler-utils (PDF text/image extraction)	GPL-2.0/3.0	Alpine package in the app image, invoked as a separate process (not linked). Shipping the image to customers carries GPL source-availability duties for poppler itself; under the usual reading, first-party code is unaffected.
Tesseract OCR + language data	Apache-2.0	Baked into the image; invoked as a separate process.
Node.js, Alpine base image	MIT · mixed OSS	Standard runtime base.
PostgreSQL 16 (+ <code>pg_trgm</code>)	PostgreSQL Licence	External database; permissive.
Adminer (DB admin UI)	Apache-2.0 / GPL-2.0 dual	Development convenience only; to be kept on a private interface or excluded from production stacks.

Model weights

LAAM does not ship model weights. The licence depends on the model the operator selects. Open-weight models run locally through Ollama, and each is governed by its own model card (for example Apache-2.0 for many Qwen-family releases; custom terms of use for some other families). Cloud models are consumed as services under each provider's terms. **TO BE COMPLETED** – record the approved model list and each model's licence for customer deployments.

6.4 External-service dependencies and vendor risk

Dependency	Exposure	Mitigation in the design
LLM providers	Answer quality, latency and cost depend on the provider	Five providers behind one router, chosen per deployment; the OpenAI-compatible adapters use plain HTTP (no vendor SDK), so switching is a configuration change, and a fully local \$0 tier is always available. No automatic mid-turn failover (§4.2): an outage needs an operator configuration change.
Web search	Upstream search engines	Self-hosted with no API key. Fails soft: chat continues without web results.
SaaS connectors	Third-party API changes, OAuth app approval, rate limits	One interface per connector; OAuth refresh serialised under a database lock; a dead grant surfaces as "needs reconnect". Any MCP-capable system can be added without code.
Geo and weather	Public community endpoints with fair-use policies	Responses are cached and throttled. Production use needs self-hosted instances or paid tiers.

Dependency	Exposure	Mitigation in the design
Speech-to-text	Browser vendor's speech service	A swappable interface is in place; self-hosted Whisper is planned (§5.2).
Framework and auth libraries	Next.js 16 / React 19 upgrade cadence; auth library is Auth.js v5 beta	Versions pinned exactly in the manifest; broad test suite for regression detection.

A Appendix – dependency licence table

All 33 production dependencies (grouped rows share one licence), audited offline on 2026-09-24 at [7eb0724](#). Dev-only tooling is excluded; the transitive closure is summarised in §6.2.

Package	Version	Licence	Purpose in LAAM
next	16.2.7	MIT	Application framework
react / react-dom	19.2.7	MIT	UI runtime
next-auth · @auth/drizzle-adapter	5.0.0-beta.31 / 1.11.2	ISC	Authentication and its persistence adapter
bcryptjs	3.0.3	BSD-3-Clause	Password hashing
drizzle-orm	0.45.2	Apache-2.0	Typed SQL / ORM
pg	8.21.0	MIT	PostgreSQL driver
zod	4.4.3	MIT	Input and schema validation
@anthropic-ai/sdk	0.104.1	MIT	Anthropic provider adapter
@modelcontextprotocol/sdk	1.29.0	MIT	MCP client (LAAM's own MCP server is hand-written JSON-RPC)
@xyflow/react	12.11.0	MIT	Workflow editor and session graph
recharts	3.8.1	MIT	Charts
leaflet	1.9.4	BSD-2-Clause	Maps
react-leaflet	5.0.0	Hippocratic-2.1	React bindings for maps (see §6.2)
three · @react-three/fiber · @react-three/drei	0.184.0 / 9.6.1 / 10.7.7	MIT	3D rendering for the voice command centre
ogl	1.0.11	Unlicense	Lightweight WebGL visuals
@ricky0123/vad-web	0.0.29	ISC	Voice-activity detection (barge-in)
react-markdown	10.1.0	MIT	Markdown rendering
streamdown	2.5.0	Apache-2.0	Streaming markdown renderer (optional spike)
remark-gfm · remark-parse · remark-rehype · rehype-sanitize · rehype-stringify · unified · unist-util-visit	4.0.1–11.1.2	MIT	Markdown → sanitised HTML (7 packages)
react-syntax-highlighter	16.1.1	MIT	Code highlighting
jspdf	4.2.1	MIT	PDF export
pdfjs-dist	6.0.227	Apache-2.0	Client-side PDF reading (fallback)
lucide-react	1.17.0	ISC	Icons